

Otim 4626 Actions Review

I conducted a 2 day review of 5 new actions which were mostly related to the implementation of 4626 yield integrations. The actions reviewed were DepositERC4626Action, SweepDepositERC4626Action, SweepWithdrawERC4626Action, WithdrawERC4626Action, CallOnceAction. Otim requested particular attention be paid to any exposure to the inflation or front running bugs in ERC4626, so we will presume that such bugs may exist in the 4626 and are not fixed by that contract. The review was preformed from commit 27bb834 .

Disclaimer: Security review is performed on a best effort basis and some bugs may remain.

About The Team

Aleph_v is a former mathematician and current cryptographer and security researcher with 7 years of experience performing security reviews and finding critical bugs for clients across the blockchain and cryptography industries.

Contact: Twitter - https://twitter.com/aleph_v (https://twitter.com/aleph_v) or Telegram - aleph_v

Findings

Summary: Critical: 0, High: 1, Medium: 0, Low: 1

Findings are presented chronologically:

- Incorrect inflation bug remediation in DepositERC4626Action and SweepDepositERC4626Action: the deposit actions implement a check that the `totalAssets` method of 4626 returns over a user specified limit with the intention that this should protect from the commonly seen 4626 inflation bug. However this check is totally ineffective as the second step of the common front running bug is to donate assets to the vault which will increase the value returned by `totalAssets` function as the assets donated are owned by the vault. Therefore this check at most increases the amount of donation needed to the asset limit, but does not otherwise protect from the common inflation bug in 4626.
 - Severity Rating: High [Likelihood: Medium, Impact: High]
 - Remediation Recommendation: Enforce checks on the total supply of 4626 shares and or share rates.
 - Remediation Status: Fixed
 - Note: It is my opinion that this bug should be resolved by the 4626.
- Incorrect configuration of the withdraw action can lead to locked deposits: The withdraw action post the fix for the with using `totalAssets` uses `totalSupply` instead but then keeps a check in the WithdrawERC4626Action. This means that if the user signs a withdraw threshold and then the threshold is passed by future withdraws from other users the user's withdraw will be unable to be processed and will fail. Such a misconfiguration is rare and easily fixable.

- Severity Rating: Low [Likelihood: Low, Impact: Medium]
 - Remediation Recommendation: Remove this restriction, since it does not address a bug in this case
 - Remediation Status: Fixed
-
- Unintentional infinite calls possible in Sweep *4626 actions: both of the sweep actions compare the amount of tokens to deposit or withdraw to the `maxDeposit` or `maxWithdraw` functions which the ERC4626 provides to inform users of which actions will revert. The sweep actions will continue till they clear the whole amount of either shares in the account or funds to be deposited. If for some reason the protocol sets their `maxDeposit` or `maxWithdraw` to a very low number like 1 wei then this would create a very large number of user actions draining the user account's gas budget.
 - Severity Rating: Medium [Likelihood: Low, Impact: High]
 - Remediation Recommendation: Add some user set min values for these calls so they can configure themselves when the gas is useful for many small calls.
 - Remediation Status: Fixed

Notes

Very low severity, performance notes, or other non-issue comments

-